FIAP – FACULDADE DE INFORMÁTICA E ADMINISTRAÇÃO PAULISTA

DEFESA CIBERNÉTICA

GRUPO – PURPLEFOX SECURITY

RELATÓRIO CHALLENGE CEAP – FASES 1 E 2

Planejamento, Proposta Detalhada e Mapeamento Operacional

Orientador: Prof. Silvio Cesar Roxo Giavaroto

Coorientador: Coord. André Luis Cirino

Turma: 1TDCOR – 1º Semestre

São Paulo

2025

Regis Ramos Pinheiro – RM 567534
Thomás Henrique Pandolfo de Campos – RM 567744
Suzana Maciel da Silva – RM 566914
Dyego de Souza Evaristo – RM 566801
Marcello Paixão da Cruz – RM 567205

RELATÓRIO CHALLENGE CEAP – FASES 1 E 2

Planejamento, Proposta Detalhada e Mapeamento Operacional

Relatório do 1º Semestre do curso de Defesa Cibernética referente ao Challenge (Constando a proposta detalhada e mapeamento de planejamento operacional) referente à empresa CEAP.

Orientador: Prof. Silvio Cesar Roxo Giavaroto
Coorientador: Coord. André Luis Cirino

São Paulo
2025

SUMÁRIO

1 FASE 1 – INTRODUÇÃO E PROPOSTA DETALHADA 4
1.1 Introdução 4
1.2 Objetivos 4
1.3 Metodologia 4
1.4 Justificativa e Importância 5
1.5 Escopo e Limites 5
1.6 Ferramentas e Frameworks 6
1.7 Cronograma 7
2 FASE 2 – MAPEAMENTO DO AMBIENTE E PLANEJAMENTO OPERACIONAL 7
2.1 WHOIS – Informações do Domínio 7
2.2 WHOIS – Informações de Infraestrutura (IP 177.190.193.105) 9
2.3 DNS – Análise Completa 11
2.3.1 Registro A / CNAME 11
2.3.2 Registros NS, MX, TXT, ANY e SOA 11
2.3.3 Registros TXT 13
2.3.4 Resumo DNS 13
2.4 Subdomínios Identificados (Força Bruta Passiva) 14
2.5 Fingerprinting (CURL) 15
2.6 SSL/TLS – Verificação com Nmap em Modo Seguro 18
2.7 HAProxy – Exposição do Endpoint /metrics 20
3 CONSIDERAÇÕES FINAIS 26

RESUMO

Este relatório consolida a Fase 1 e a Fase 2 do desafio CEAP 2025. A Fase 1 descreve a introdução, justificativa, objetivos e proposta detalhada do teste ético em ambiente de homologação. A Fase 2 apresenta o mapeamento do ambiente, incluindo análise de domínio, DNS, infraestrutura, serviços expostos e identificação da superfície de ataque, sem qualquer varredura agressiva ou exploração, respeitando o escopo aprovado.

Palavras-chave: Pentest. Reconhecimento passivo. WHOIS. DNS. Defesa cibernética. CEAP.

1 FASE 1 – INTRODUÇÃO E PROPOSTA DETALHADA

1.1 Introdução

O presente relatório descreve as etapas iniciais do processo de avaliação de segurança autorizada em ambiente de homologação, com foco em testes éticos de baixa intrusão.

Nesta fase, o objetivo é estruturar o planejamento, escopo, justificativa e metodologia, além de mapear tecnicamente o ambiente-alvo para possibilitar os testes de segurança futuros.

1.2 Objetivos

Objetivo Geral

Estabelecer a base técnica e metodológica necessária para a futura execução do teste ético de segurança em ambiente de homologação.

Objetivos Específicos

- Definir a proposta detalhada do teste ético.
- Delimitar escopo, limites e responsabilidades.
- Identificar os ativos envolvidos e a superfície de ataque inicial.
- Realizar mapeamento passivo da infraestrutura.
- Organizar cronograma e ferramentas que serão utilizadas nas fases futuras.

1.3 Metodologia

A metodologia adotada baseia-se nos seguintes padrões:

- PTES – Penetration Testing Execution Standard;
- NIST SP 800-115;
- OWASP Testing Guide.

Para este relatório, apenas as etapas permitidas no escopo são utilizadas, conforme o Quadro 1.

Quadro 1 – Etapas metodológicas aplicadas

Etapa	Descrição
Fase 1 – Planejamento	Definição de limites, objetivos, justificativas, riscos e responsabilidades.
Fase 2 – Reconhecimento Passivo	Coleta de informações sem interação agressiva: WHOIS, DNS, fingerprinting, subdomínios, certificados TLS.

Fonte: Elaborado pelos autores (2025).

1.4 Justificativa e Importância

A defesa proativa exige a identificação antecipada de falhas antes que atacantes possam explorá-las. O teste ético autorizado proporciona os seguintes benefícios à organização:

- Redução de riscos operacionais e financeiros;
- Prevenção de incidentes de segurança;
- Conformidade com a LGPD (Lei nº 13.709/2018);
- Proteção da reputação institucional;
- Validação das configurações de segurança existentes.

1.5 Escopo e Limites

O trabalho consiste em um Vulnerability Assessment Passivo, sem qualquer ação de exploração. O Quadro 2 lista as atividades permitidas e proibidas no escopo aprovado.

Quadro 2 – Atividades permitidas e proibidas

Classificação	Atividade
Permitida	Análise de registros DNS
Permitida	Fingerprinting por headers HTTP
Permitida	Identificação de tecnologias
Permitida	Mapeamento passivo de subdomínios
Permitida	Verificação de certificado TLS
Proibida	Exploração de vulnerabilidades
Proibida	Injeção de dados (SQLi, XSS etc.)
Proibida	Aumento de impacto ou privilégio
Proibida	Qualquer ação que modifique dados

Fonte: Elaborado pelos autores (2025).

1.6 Ferramentas e Frameworks

O Quadro 3 apresenta as ferramentas e frameworks utilizados nas Fases 1 e 2.

Quadro 3 – Ferramentas e frameworks utilizados

Ferramenta / Framework	Finalidade
Whois	Consulta de registros de domínio e IP
Dig	Análise de registros DNS
Curl	Fingerprinting de headers HTTP
Nmap (modo seguro)	Verificação de certificados SSL/TLS
Crt.sh / Amass (passive)	Enumeração passiva de subdomínios

Ferramentas de navegador (F12)	Análise de headers e comportamento web
OWASP / NIST / MITRE ATT&CK	Frameworks de metodologia e referência

Fonte: Elaborado pelos autores (2025).

1.7 Cronograma

O Quadro 4 apresenta o cronograma de execução do projeto.

Quadro 4 – Cronograma de fases do projeto

Fase	Descrição	Status
Fase 1	Introdução e Planejamento	Concluída
Fase 2	Mapeamento do Ambiente	Concluída
Fase 3	Varredura e Identificação de Vulnerabilidades	Próximo Semestre
Fase 4	Validação e Relatório Final	Próximo Semestre

Fonte: Elaborado pelos autores (2025).

2 FASE 2 – MAPEAMENTO DO AMBIENTE E PLANEJAMENTO OPERACIONAL

A seguir, todo o mapeamento realizado utilizando WHOIS, DNS, CURL e Nmap em modo seguro:

2.1 WHOIS – Informações do Domínio

O Whois é um protocolo e uma ferramenta de linha de comando que consulta bancos de dados públicos para obter informações sobre o registro de nomes de domínio, endereços IP e

outros recursos da internet. É utilizado para descobrir informações administrativas e de contatos.

Comandos utilizados:

```
whois pedreira.org
whois -h whois.iana.org pedreira.org
```

Resultados principais:

Quadro 5 – Informações WHOIS do domínio pedreira.org

Campo	Valor
Registrar	eNom, LLC (IANA 48)
Registry	PIR – Public Interest Registry
DNS	Cloudflare
DNSSEC	Unsigned
Data de Criação	08/04/2008
Data de Expiração	08/04/2026

Fonte: Elaborado pelos autores com base em consulta whois (2025).

A Figura 1 apresenta a saída completa do terminal referente à consulta WHOIS do domínio.

Whois : é um protocolo e uma ferramenta de linha de comando que consulta bancos de dados públicos para obter informações sobre o registro de nomes de domínio, endereços IP e outros recursos da internet. Ele é usado para descobrir informações administrativas e de contatos.

Comandos:
whois pedreira.org - whois -h whois.iana.org pedreira.org

Resultados principais:

Registrar: eNom, LLC (IANA 48)

Registry: PIR – Public Interest Registry

DNS: Cloudflare

DNSSEC: Unsigned

Criação: 08/04/2008

Expiração: 08/04/2026

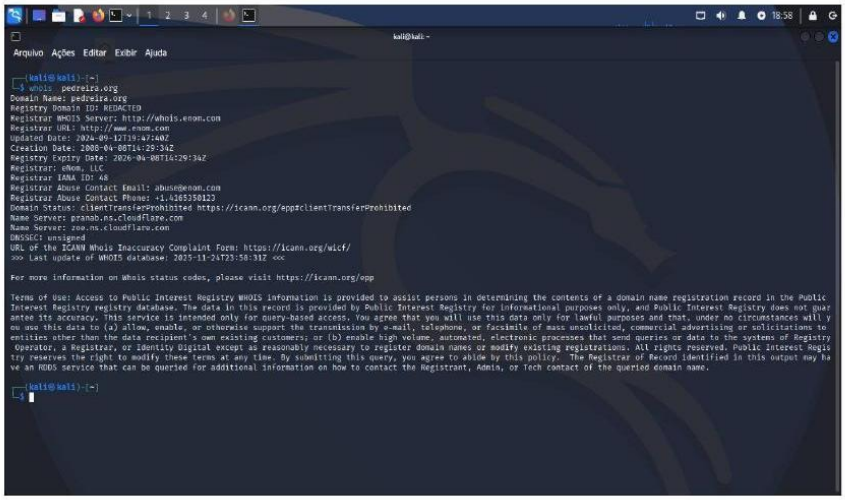

Figura 1 – Saída do comando whois pedreira.org

Fonte: Captura de tela dos autores (2025).

2.2 WHOIS – Informações de Infraestrutura (IP 177.190.193.105)

Comando utilizado:

```
whois 177.190.193.105
```

Resultado:

Quadro 6 – Informações WHOIS do IP 177.190.193.105

Campo	Valor
Alocado a	CTINET Soluções – Brasil
Contato	registro.br@cti.com.br

Fonte: Elaborado pelos autores com base em consulta whois (2025).

A Figura 2 apresenta a saída completa do terminal referente à consulta WHOIS do IP.

Comando:
whois 177.190.193.105

Resultado:

Alocado a: CTINET Soluções – Brasil

Contato: registro.br@cti.com.br

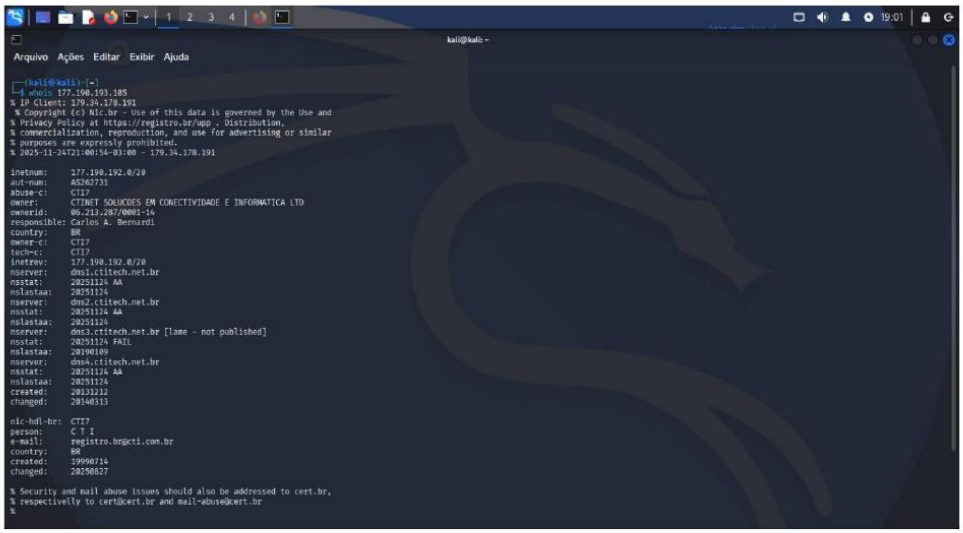

Figura 2 – Saída do comando whois 177.190.193.105

Fonte: Captura de tela dos autores (2025).

2.3 DNS – Análise Completa

Para esta análise foi utilizado o comando dig, ferramenta de linha de comando que consulta o Sistema de Nomes de Domínio (DNS). As siglas a seguir correspondem aos tipos de registros DNS consultados.

2.3.1 Registro A / CNAME

```
dig CNAME dev.pedreira.org
dig +short A dev.pedreira.org
```

Consulta	Resultado
dig CNAME dev.pedreira.org	ceap.dyndns.org
dig +short A dev.pedreira.org	177.190.193.105

Fonte: Elaborado pelos autores (2025).

2.3.2 Registros NS, MX, TXT, ANY e SOA

```
dig NS pedreira.org
dig MX pedreira.org
dig ANY pedreira.org
dig SOA pedreira.org
```

Resultado NS: Cloudflare. Resultado MX: smtp.google.com. A Figura 3 apresenta as saídas dos registros NS e demais consultas DNS.

DNS – Análise Completa

Para esta análise, foi-se utilizado o comando dig, é uma ferramenta de linha de comando que consulta o Sistema de Nomes de Domínio (DNS). Essas siglas incluídas são os Tipos de Registros DNS.

Registro A / CNAME

- dig CNAME dev.pedreira.org
  ceap.dyndns.org
- dig +short A dev.pedreira.org
  177.190.193.105

Registros NS

- dig NS pedreira.org
  Cloudflare

Figura 3 – Saída das consultas DNS (NS, MX, TXT, SOA)

Fonte: Captura de tela dos autores (2025).

Registros MX

- dig MX pedreira.org
  smtp.google.com

Registros TXT

- SPF configurado
- DKIM ausente
- DMARC ausente

Registros ANY (qualquer registro)

- dig ANY pedreira.org

Registros SOA

- Dig SOA pedreira.org

Resumo DNS

Subdomínio: dev.pedreira.org

CNAME → ceap.dyndns.org

Figura 4 – Saída das consultas MX, SOA e Resumo DNS

Fonte: Captura de tela dos autores (2025).

2.3.3 Registros TXT

Registro	Status
SPF	Configurado
DKIM	Ausente
DMARC	Ausente

Fonte: Elaborado pelos autores (2025).

2.3.4 Resumo DNS

Item	Detalhe
Subdomínio	dev.pedreira.org
CNAME	ceap.dyndns.org
IP Real	177.190.193.105
E-mails	Google Workspace
Autoridade DNS	Cloudflare

Fonte: Elaborado pelos autores (2025).

2.4 Subdomínios Identificados (Força Bruta Passiva)

Comando utilizado:

```
for sub in www api dev test mail vpn portal admin stage beta; do
  dig +short $sub.pedreira.org
done
```

Os resultados da enumeração passiva de subdomínios são apresentados no Quadro 7 e na Figura 5.

Quadro 7 – Subdomínios identificados

Subdomínio	Resultado
www.pedreira.org	Cloudflare
dev.pedreira.org	ceap.dyndns.org
Demais (api, test, mail, vpn, portal, admin, stage, beta)	Sem resposta (vazios)

Fonte: Elaborado pelos autores (2025).

[redacted]

Subdomínios identificados (Força bruta passiva)

Comando: dig + short $sub.pedreira.org;

for sub in www api dev test mail vpn portal admin stage beta; do
done

Retorno:

www.pedreira.org → Cloudflare

dev.pedreira.org → ceap.dyndns.org

Outros: vazios.

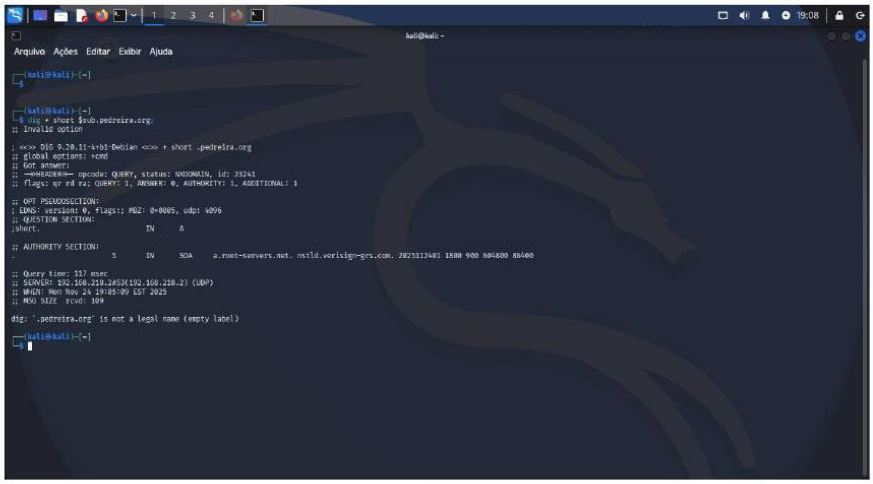

Figura 5 – Enumeração passiva de subdomínios

Fonte: Captura de tela dos autores (2025).

2.5 Fingerprinting (CURL)

O curl foi utilizado para realizar requisições web diretamente da linha de comando, identificando o comportamento do servidor, redirecionamentos e cabeçalhos de resposta HTTP.

Comandos utilizados:

```
curl -I http://dev.pedreira.org
curl -I https://dev.pedreira.org/dev
curl -v https://dev.pedreira.org
```

Os resultados são apresentados no Quadro 8 e nas Figuras 6 e 7.

Quadro 8 – Resultados do fingerprinting via CURL

Teste	Resultado
curl -I http://dev.pedreira.org	Redirect 302 para HTTPS
curl -I https://dev.pedreira.org/dev	Redirect para /dev
curl -v https://dev.pedreira.org	TLS 1.3 | Certificado válido (GlobalSign) | HSTS ativo | Server headers minimalistas

Fonte: Elaborado pelos autores (2025).

- curl -v https://dev.pedreira.org

Certificado válido (GlobalSign)

HSTS ativo

Server headers minimalistas

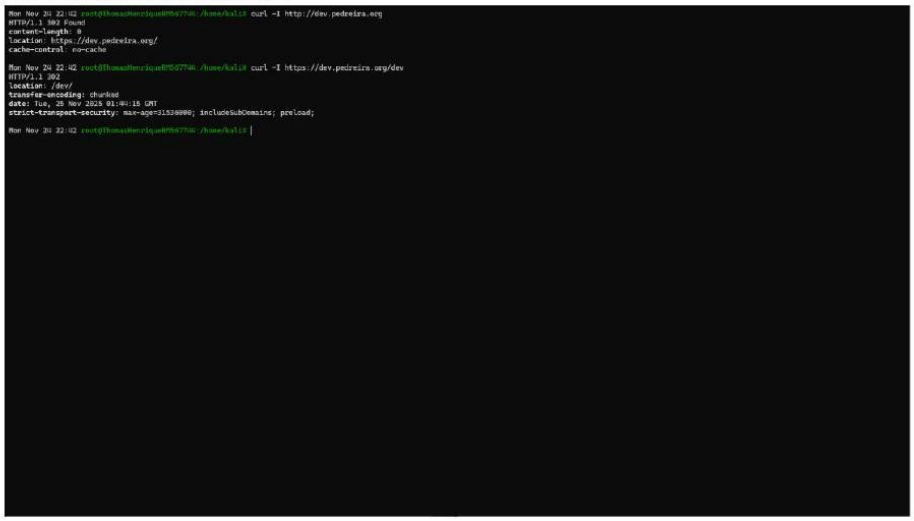

Figura 6 – Saída do comando curl -I (redirect HTTP para HTTPS)

Fonte: Captura de tela dos autores (2025).

[redacted]

SSL / TLS (Nmap em modo seguro)

Nmap: comando usado para descobrir dispositivos e serviços em uma rede, um "mapa" que mostra quem está conectado e o que cada um está fazendo, aqui foi buscada evidências pela porta 443 que é utilizada para HTTPS.

nmap --script ssl-cert,ssl-enum-ciphers -p 443 dev.pedreira.org

Resultados:

Certificado válido (2025–2026)

Emitido pela GlobalSign

Suporte a TLS 1.3

Suíte modernas (AES-GCM / CHACHA20) - Boa segurança

Figura 7 – Saída do comando curl -v (TLS handshake e headers)

Fonte: Captura de tela dos autores (2025).

2.6 SSL/TLS – Verificação com Nmap em Modo Seguro

O Nmap foi utilizado para identificar configurações de certificado e suporte a versões TLS na porta 443 (HTTPS). Nenhuma varredura agressiva foi realizada.

Comando utilizado:

```
nmap --script ssl-cert,ssl-enum-ciphers -p 443 dev.pedreira.org
```

Os resultados são apresentados no Quadro 9 e na Figura 8.

Quadro 9 – Resultados da análise SSL/TLS

Item	Resultado
Validade do certificado	2025 – 2026
Emitido por	GlobalSign
Versão TLS suportada	TLS 1.3
Suítes de cifra	AES-GCM / CHACHA20 — Boa segurança

Fonte: Elaborado pelos autores (2025).

HAProxy

HAProxy é um software livre e de código aberto que funciona como um balanceador de carga e servidor proxy de alta disponibilidade para aplicativos baseados em TCP e HTTP. Ele distribui o tráfego de rede entre vários servidores para melhorar o desempenho, a confiabilidade e a escalabilidade das aplicações.

Contudo, foi identificado o endpoint /robots.txt, que não retornou nada sensível, já utilizando o /metrics acessível publicamente sem autenticação via HTTPS. A análise do conteúdo revelou informações de infraestrutura e foi identificado um alerta crítico, a proporção de requisições com erro no Tomcat com muitos erros excessivos, tendo como causas prováveis:

- Um bot ou scanner de vulnerabilidades varrendo URLs inexistentes (gerando muitos 404).
- Um health check mal configurado batendo em um endpoint errado a cada poucos segundos.
- Uma falha sistêmica em uma das aplicações implantadas.

Seguindo, os dados também exponham versão do apache (9.0.93.0), que pode ser tomada como base para identificar vulnerabilidades. Além disso também há outro alerta, há um comportamento anômalo do Garbage Collector (coletor de lixo G1 GC), está invertido em relação ao padrão saudável, o sistema está fazendo 10 vezes mais coletas pesadas do que leves, podendo indicar vazamento de memória (uma das possibilidades). Estão expostas também outras URLs do site. A versão do Tomcat está atualizada.

Figura 8 – Saída do Nmap: ssl-cert e ssl-enum-ciphers

Fonte: Captura de tela dos autores (2025).

2.7 HAProxy – Exposição do Endpoint /metrics

HAProxy é um software livre e de código aberto que funciona como balanceador de carga e servidor proxy de alta disponibilidade para aplicativos baseados em TCP e HTTP. Ele distribui o tráfego de rede entre vários servidores para melhorar desempenho, confiabilidade e escalabilidade das aplicações.

Foi identificado o endpoint /robots.txt, que não retornou conteúdo sensível. O endpoint /metrics, por sua vez, encontrava-se acessível publicamente sem autenticação via HTTPS. A análise de seu conteúdo revelou informações de infraestrutura e os alertas críticos descritos no Quadro 10.

Quadro 10 – Alertas identificados no endpoint /metrics

Alerta	Descrição	Causa Provável
Erros excessivos no Tomcat	Alta proporção de requisições com erro	Bot/scanner varrendo URLs inexistentes (404) ou health check mal configurado
Versão do Apache exposta	Versão 9.0.93.0 visível publicamente	Pode ser utilizada como base para pesquisa de CVEs
Garbage Collector anômalo	10× mais coletas pesadas do que leves (G1 GC)	Possível vazamento de memória na aplicação

Fonte: Elaborado pelos autores (2025).

A versão do Tomcat encontra-se atualizada. As informações expostas pelo /metrics, embora não diretamente exploráveis nesta fase, fornecem inteligência valiosa para as fases futuras de testes. As Figuras 9, 10 e 11 apresentam as capturas de tela do endpoint /metrics.

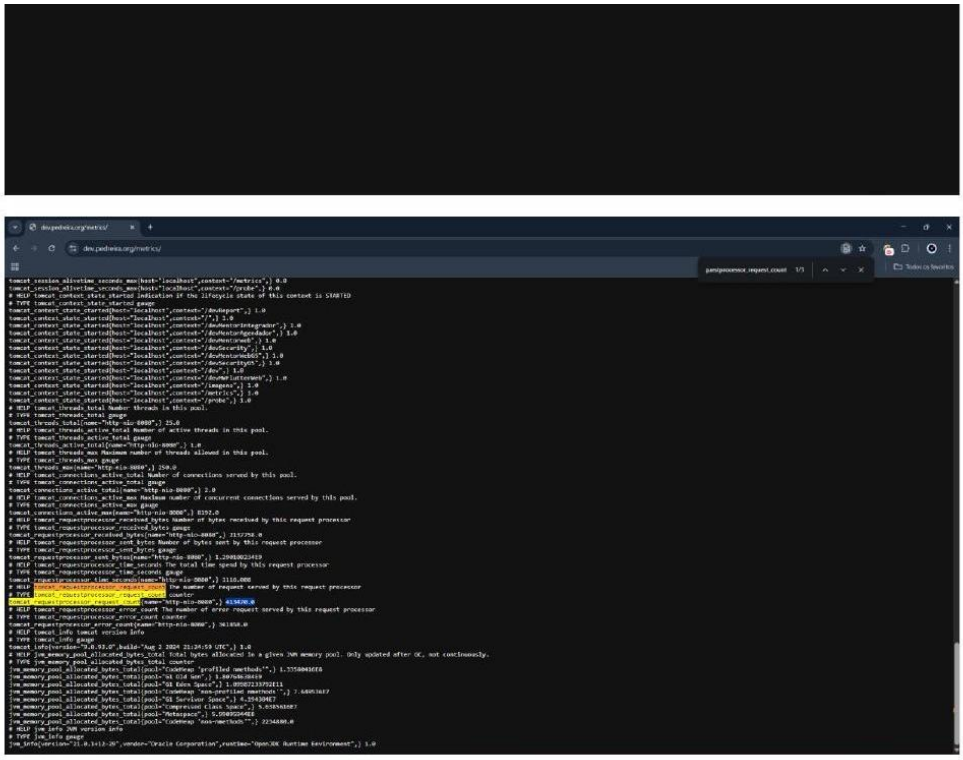

Figura 9 – Endpoint /robots.txt e início do /metrics

Fonte: Captura de tela dos autores (2025).

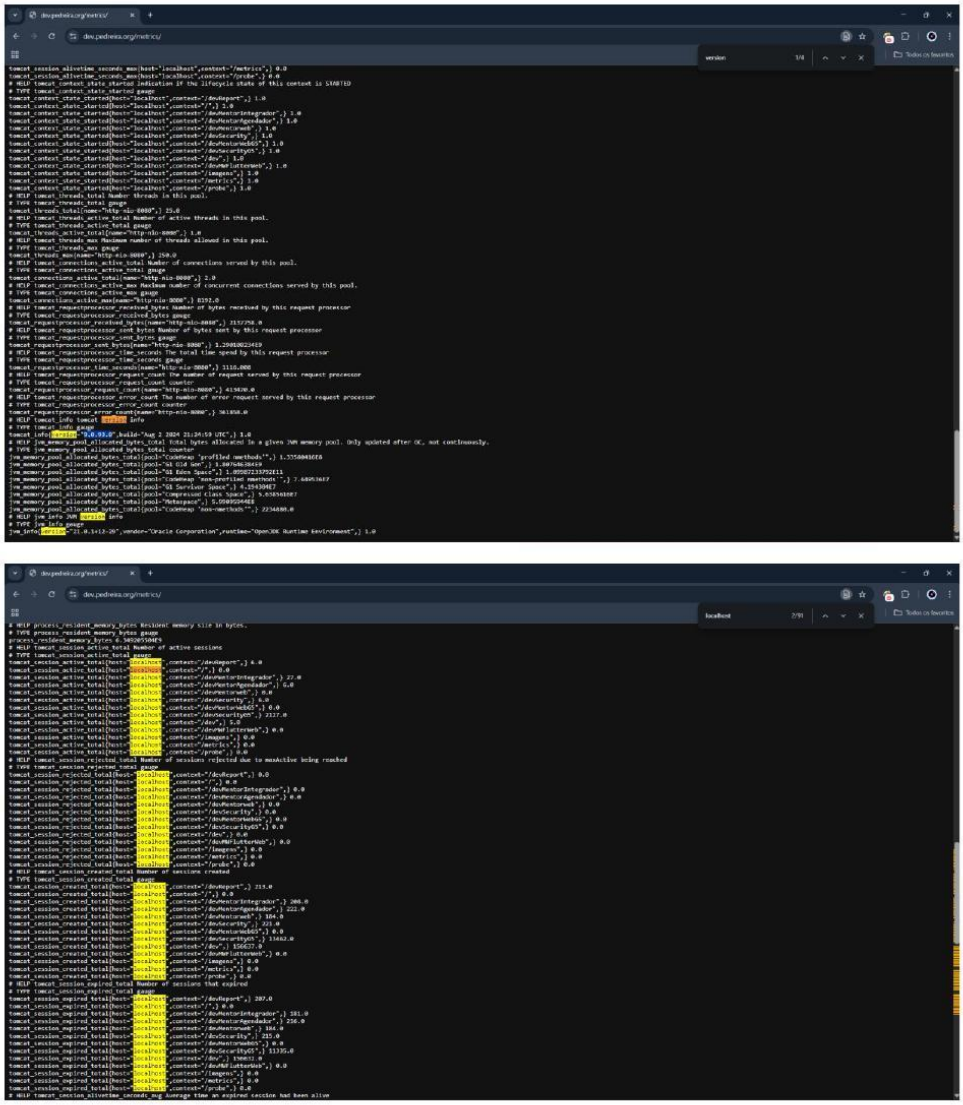

Figura 10 – Métricas expostas do HAProxy/Tomcat (parte 1)

Fonte: Captura de tela dos autores (2025).

CONSIDERAÇÕES FINAIS

Com a conclusão da Fase 1 e Fase 2, estabeleceu-se:

Documentação completa do domínio, DNS e infraestrutura

Identificação da superfície de ataque

Planejamento metodológico aprovado

Definição clara de escopo e limites técnicos

Reconhecimento passivo completo, sem impacto no ambiente

A infraestrutura apresenta padrões de segurança adequados no nível superficial.
A continuidade (Fases 3 e 4) deverá ocorrer no próximo semestre, com testes controlados de vulnerabilidades.

REFERÊNCIAS

OWASP Testing Guide

https://owasp.org/www-project-web-security-testing-guide/

PTES – Penetration Testing Execution Standard

http://www.pentest-standard.org/index.php/Main_Page

NIST SP 800-115

https://www.nist.gov/privacy-framework/nist-sp-800-115

RFC 8482

Documentação WHOIS / DIG / Cloudflare DNS

Nmap NSE Manual

Figura 11 – Métricas expostas do HAProxy/Tomcat (parte 2)

Fonte: Captura de tela dos autores (2025).

3 CONSIDERAÇÕES FINAIS

Com a conclusão da Fase 1 e da Fase 2, foram estabelecidos os fundamentos técnicos e metodológicos necessários para a continuidade do projeto. Os resultados obtidos nesta etapa incluem:

- Documentação completa do domínio, DNS e infraestrutura;
- Identificação da superfície de ataque;
- Planejamento metodológico aprovado;
- Definição clara de escopo e limites técnicos;
- Reconhecimento passivo completo, sem impacto no ambiente.

A infraestrutura avaliada apresenta padrões de segurança adequados no nível superficial. Contudo, a exposição pública do endpoint /metrics e a ausência de registros DKIM e DMARC representam pontos de atenção que deverão ser investigados nas fases seguintes.

A continuidade do projeto (Fases 3 e 4) deverá ocorrer no próximo semestre, com testes controlados de identificação e validação de vulnerabilidades, sempre dentro do escopo aprovado.

REFERÊNCIAS

OWASP FOUNDATION. OWASP Testing Guide v4.2. Disponível em: <https://owasp.org/www-project-web-security-testing-guide/>. Acesso em: 2025.

ISECOM. PTES – Penetration Testing Execution Standard. Disponível em: <http://www.pentest-standard.org/index.php/Main_Page>. Acesso em: 2025.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. NIST SP 800-115: Technical Guide to Information Security Testing and Assessment. Gaithersburg, MD: NIST, 2008. Disponível em: <https://www.nist.gov/privacy-framework/nist-sp-800-115>. Acesso em: 2025.

INTERNET ENGINEERING TASK FORCE. RFC 8482: Providing Minimal-Sized Responses to DNS Queries That Have QTYPE=ANY. 2019.

CLOUDFLARE. Documentação DNS Cloudflare. Disponível em: <https://developers.cloudflare.com/dns/>. Acesso em: 2025.

NMAP PROJECT. Nmap NSE Documentation. Disponível em: <https://nmap.org/nsedoc/>. Acesso em: 2025.